Assignment 1: TCP/IP methods and Attack Methods

TNM031 – 2026

Name1: _____

Name2: _____

A. TCP/IP protocol and Security

1. **Why is the IP protocol unreliable?**

   IP is a best-effort, connectionless protocol. It just sends packets and does not check if they arrive, arrive in order, or arrive only once. Lost or damaged packets are not resent, so IP gives no guarantee of delivery.

2. **IP is unreliable, and TCP uses IP. How does TCP provide reliable service to the application layer?**

   TCP is connection oriented. It first sets up a connection with the three-way handshake (SYN, SYN-ACK, ACK). After that every segment gets a sequence number, and the receiver sends back acknowledgements (ACKs). If the sender does not get an ACK in time it retransmits the segment. A checksum detects damaged segments, and the sequence numbers let the receiver put segments back in the right order and throw away duplicates.

3. **What does TCP do if the message to be sent is larger than what a single datagram can handle?**

   TCP splits (fragments) the message into several segments, each with its own sequence number. Each segment is sent in its own IP packet, and the receiving TCP uses the sequence numbers to reassemble the original message before giving it to the application.

4. **What are the minimum and maximum header size of IP packets?**

   For IPv4 the minimum header is 20 bytes (no options) and the maximum is 60 bytes. The header length field is 4 bits and counts 32-bit words, so the max is $15 \times 4 = 60$ bytes.

5. **An IP packet arrives at a router with the first eight bits as 01000011. The router discards the packet. Why?**

   The first four bits (0100) is the version, i.e. IPv4, which is fine. The next four bits (0011) is the header length = 3, which means $3 \times 4 = 12$ bytes. The minimum IPv4 header is 20 bytes (value 5), so the header is invalid and the packet is dropped.

6. **Why is it necessary to have both IP address and port number in a packet?**

   The IP address only gets the packet to the right host. The port number tells the transport layer which application/process on that host the data belongs to (e.g. 80 for a web server, 25 for SMTP). Many applications run on the same host, so both are needed (together they form a socket).

7. **Which of the protocols TCP, UDP and IP provides for reliable communication?**

   Only TCP. IP and UDP are both connectionless and do not resend lost data.

B. Scanning Attacks

8. **What is the purpose of host scanning?**

   To find out which IP addresses in a network actually have live hosts on them. It is part of reconnaissance, the attacker builds a map of the network before choosing targets.

9. **How does ping scanning work?**

   The attacker sends ICMP echo request messages (pings) to a range of IP addresses. Hosts that are up answer with an ICMP echo reply, so every reply means a live host. Tools like nmap can sweep a whole range with one command.

10. **Why are ping scans often not effective?**

    Most firewalls drop incoming ICMP echo requests (and many hosts are set not to answer them), so no reply comes back even though the host is alive. Ping sweeps are also easy to detect.

11. **Why are SYN/ACK scans done?**

    A SYN/ACK looks like the reply to a connection that an internal host started, so simple firewalls often let it through when they would block pings. The target never sent a SYN, so it answers with a RST, and that RST tells the attacker the host exists.

12. **How may hosts respond to SYN/FIN messages?**

    SYN and FIN set at the same time is an illegal combination (open and close a connection at once). Different operating systems handle it differently: some reply with RST, some with SYN/ACK and some ignore it. Any reply reveals the host, and the type of reply can also be used to guess the OS.

13. **How does Traceroute (or Tracert) work?**

    It sends packets to the target with TTL starting at 1 and then increasing by one each round. Each router decrements TTL, and the router where it hits 0 drops the packet and sends back an ICMP Time Exceeded message, which reveals that router's address. Repeating this gives the whole path to the target, i.e. the network topology, which is useful for planning an attack.

14. **Why is port scanning done?**

    To find out which ports are open on a host and therefore which services/applications are running. The attacker can then look for known vulnerabilities in those applications. It can also reveal things like whether anonymous login is allowed or authentication is needed.

15. **How does TCP port scanning work?**

    The attacker sends a SYN to each port on the target. A SYN/ACK back means the port is open (something is listening), a RST means it is closed, and no reply usually means it is filtered by a firewall. Often the attacker never finishes the handshake (half-open scan).

16. **Why is sending a long stream of scanning messages dangerous for attackers?**

    A big burst of probes from one source is easy for an IDS or firewall log to spot. And since a scan only works if the replies come back, the attacker usually has to use their real IP address, so the scan can be traced back to them.

17. **How do attackers use stealth scanning to reduce danger in the previous question?**

    They scan slowly and in random order, e.g. only a few probes per hour, so the traffic stays below the IDS alarm thresholds and blends in with normal traffic. The scan can also be split across several source hosts, and half-open scans avoid creating full connections that get logged.

18. **What rules would you add to the firewall to prevent the SYN/ACK attack?**

    Drop incoming SYN/ACK segments that do not belong to a connection opened by an internal host (a stateful firewall does this automatically). Also drop outgoing RST segments, so internal hosts cannot answer probes and give away that they exist.

19. **How many packets would be sent by an attacker to port scan 100 hosts for all well-known ports?**

    Well-known ports are 0–1023, i.e. 1024 ports. One probe per port per host gives 100 × 1024 = **102 400 packets** (204 800 if both TCP and UDP are scanned).

C. Attack Methods Based on TCP/IP Protocol

20. **What is fingerprinting?**

    Finding out which operating system (or application version) a host runs by looking at how it handles network traffic. Every OS implements TCP/IP a bit differently, and knowing the OS lets the attacker pick exploits that work against it.

21. **Distinguish between active and passive fingerprinting.**

    Active: the attacker sends specially crafted packets (e.g. odd flag combinations, ICMP) to the host and compares the replies with known OS behaviour. Accurate, but it can be detected.
    Passive: the attacker only sniffs normal traffic from the host and looks at things like TTL, window size and options. Nothing is sent, so it is basically undetectable but less exact.

22. **Describe SYN flooding attack.**

    The attacker sends a large number of SYN packets to the server, usually with spoofed source addresses that do not exist. The server answers each with a SYN/ACK and keeps a half-open connection waiting for the final ACK, which never comes. The table for half-open connections fills up, so new legitimate connections are dropped and the server may crash. The result is a denial of service.

23. **Which measures can be deployed to avoid a SYN flooding attack?**

    • Use a firewall as a SYN proxy: it answers the SYN itself and only passes the connection to the server once the client's ACK arrives, so the server never sees half-open connections.
    • SYN cookies on the server (see 24).
    • Shorter timeout for half-open connections and a bigger backlog queue.
    • Ingress/anti-spoofing filtering at the network edge, rate limiting, and an IDS/IPS to detect the flood.

24. **Describe how SYN cookies can be used to stop a SYN flooding attack.**

    When a SYN arrives the server does not store any state. Instead it calculates its initial sequence number as a hash of the connection info (IPs, ports, a time value and a secret) and sends that in the SYN/ACK. A real client answers with an ACK containing that number + 1, so the server can recompute the hash, verify it and only then allocate the connection. Spoofed SYNs never get an ACK back, so they use no memory and the queue cannot fill up.

25. **Describe the Smurf attack.**

    The attacker sends ICMP echo requests to the broadcast address of a network, with the source IP spoofed to be the victim's address. Every host on that network replies to the victim, so one packet turns into many (amplification). The flood of echo replies overloads the victim's link and causes a denial of service. Countermeasures are to block directed broadcasts on routers and rate-limit ICMP in the firewall.

26. Describe DDoS attacks.

In a distributed DoS the attacker first takes over a lot of machines (bots/zombies) with malware. On command, usually through handler/C&C servers, all of them flood the victim at the same time (SYN, UDP, ICMP floods etc.). Because the traffic comes from thousands of different sources it is much bigger than a single attacker could produce, and it is hard to block or trace back to the real attacker.

27. List some of the attacks that do use IP address spoofing.

SYN flooding, Smurf attack, UDP flood (e.g. echo/chargen with spoofed source), TCP blind spoofing / session hijacking, DNS spoofing, IP source route attacks, and most DoS/DDoS floods in general.

28. List some of the attacks that do <u>not</u> use IP address spoofing.

Attacks where the attacker needs to see the replies: host scanning (ping sweeps), port scanning, active fingerprinting and traceroute. Also application-level attacks like XSS and cookie poisoning, and LAN attacks like DHCP starvation (spoofs MAC addresses, not IP).